Strong authentication and privileged access — KRL-ADM

Banque Kerlann (fictitious) · KRL-ADM — IAM administration console

Prepared by: **Attest (AI-assisted)**
Auditor sign-off: **pending**
Owner: **IT department — IAM team**
Date: **2026-11-04 00:14**
Run: **iam**

1. Executive summary

OPINION AT TESTING

Unsatisfactory

OPINION AFTER REMEDIATION

Unsatisfactory

Basis for opinion

7 controls tested (7 conclusive) against: DORA art. 9(4) · RTS (UE) 2024/1774 art. 12, 21 · PSI-4. Tests run on 2026-11-04 00:14, environment: Demonstration pre-production. The opinion rests solely on the verdicts of the deterministic test scripts and on the evidence sealed in the audit trail.

Scope limitation: Work programme and test scripts drafted by AI and not yet reviewed by an auditor; requirements needing document review or interview are not covered; the opinion applies at the test date only.

7 controls tested	**6** findings	**0** findings closed and verified · 5 re-tested compliant, closure pending approval	**1** open findings
0 human approvals · 5 pre-approved (demo)	**8** sensitive data items masked in evidence	**1 min 13 s** audit duration	**$0.125 *** measured AI cost



Critical: 1 · High: 2 · Medium: 3 · Low: 0

Key messages

- 6 findings across 7 controls: 1 critical, 2 high, 3 medium.
- 5 finding(s) re-tested compliant after a pre-approved change (not valid as an approval): closure pending owner approval, still counted in the opinion.
- 1 finding remains open, with an action plan, an owner and a due date.

2. Scope and method

Engagement	AUD-2026-IAM-01

Entity	Banque Kerlann (fictitious)
System	KRL-ADM — IAM administration console
System criticality	Supports critical or important functions (DORA)
Environment	Demonstration pre-production
Owner	IT department — IAM team
Lead auditor	Attest CI
Date	2026-11-04 00:14
Framework	DORA art. 9(4) · RTS (UE) 2024/1774 art. 12, 21 · PSI-4
Audited target	KRL-ADM IAM admin console (Banque Kerlann)
Work programme	existing catalogue reused · controls/AUD-2026-IAM-01.en.json

In scope

- Authentication and session settings of the KRL-ADM console
- Accounts with access to the console
- Logging of administrative actions

Out of scope

- Intrinsic strength of MFA factors (robustness of authentication means)
- Central directory and identity federation
- Physical controls

Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. Every fix goes through a change request approved by the system owner, applied with a dedicated account, logged, then verified by the same test (DORA 9(4)(e)).
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fixes are drafted by the audit tool itself (self-review threat): closing a finding requires independent approval by the system owner.
- Fictitious entity and data: demonstration.

3. Findings overview

REF.	RULE	TITLE	SEVERITY	TESTED	AFTER	STATUS	DUE DATE
F-01	PSI-4.1	Mandatory MFA for privileged accounts	Critical	Non-compliant	Compliant	**Re-tested compliant — closure pending owner approval**	2026-12-04

F-02	PSI-4.2	Mandatory MFA for users of critical system	High	Non-compliant	Compliant	Re-tested compliant — closure pending owner approval	2027-02-02
F-03	PSI-4.7	No generic or shared admin accounts	High	Non-compliant		Action plan	2027-02-02
F-04	PSI-4.3	Strong password policy	Medium	Non-compliant	Compliant	Re-tested compliant — closure pending owner approval	2027-05-03
F-05	PSI-4.4	Account lockout after failed logins	Medium	Non-compliant	Compliant	Re-tested compliant — closure pending owner approval	2027-05-03
F-06	PSI-4.5	Inactive session timeout	Medium	Non-compliant	Compliant	Re-tested compliant — closure pending owner approval	2027-05-03
—	PSI-4.6	Logging of administration actions	High	Compliant			

4. Detailed findings and controls

F-01 PSI-4.1 Mandatory MFA for privileged accounts

Critical · Non-compliant → Compliant

Re-tested compliant — closure pending owner approval

CRITERIA

MFA is enforced for all privileged admin accounts on KRL-ADM

PSI-4.1 · DORA 9(4)(d), RTS 21(1)(f)(ii)

CONDITION

Observed: `false`
Expected: `true`

GET /api/security returned mfa_admin=False.

RISK

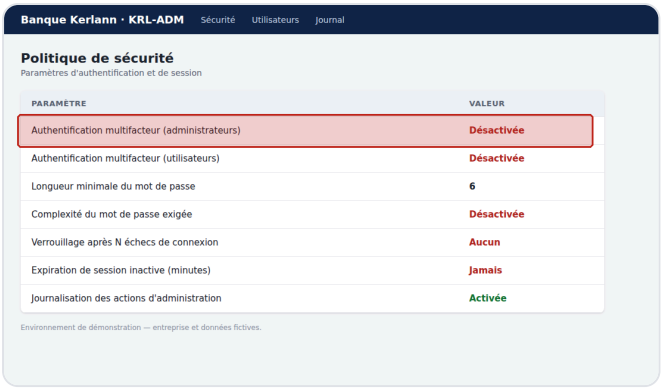
Without MFA for admins, stolen credentials allow full takeover of critical functions with no second barrier

RECOMMENDATION

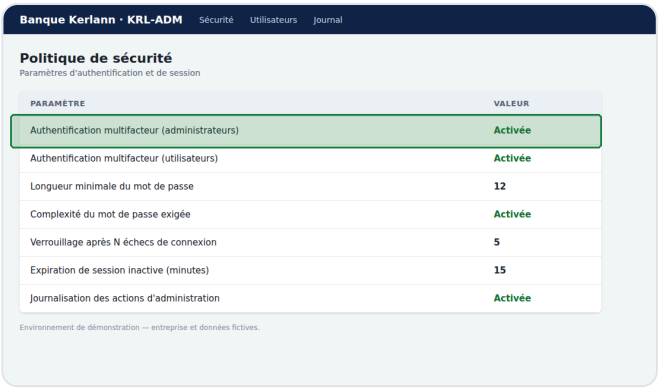
Enable mandatory MFA for all privileged accounts by setting mfa_admin to true

Due date: 2026-12-04 · Owner: IT department — IAM team

Test procedure: Retrieve the security configuration via GET /api/security and verify that mfa_admin is true



At testing — The screenshot corroborates the test. The screenshot shows administrator MFA as Désactivée, matching the API result of mfa_admin=False.
`2026-11-04 00:15:08 · SHA-256 7e61f61ba345e75d…`



After fix — The screenshot corroborates the test. The security policy table shows MFA for administrators is Activée.
`2026-11-04 00:15:53 · SHA-256 df9e11e666120d20…`

> **Change request CHG-AUD-2026-IAM-01-01** · `PATCH /api/security {"mfa_admin": true}`
> Enabling mfa_admin enforces mandatory MFA for all privileged accounts as required by PSI-4.1.
> Expected impact: Admins without MFA enrolled will be required to enroll MFA at next login.
> Approved by: **IAM owner (CI)** · 2026-11-04 00:15:39 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-04T00:15:39Z · svc-change · mfa_admin: False → True

F-02 PSI-4.2 Mandatory MFA for users of critical system

High · Non-compliant → Compliant

Re-tested compliant — closure pending owner approval

CRITERIA

MFA is enforced for standard users because KRL-ADM supports critical or important functions
PSI-4.2 · DORA 9(4)(d), RTS 21(1)(f)(ii)

CONDITION

Observed: `false`
Expected: `true`
mfa_users is False.

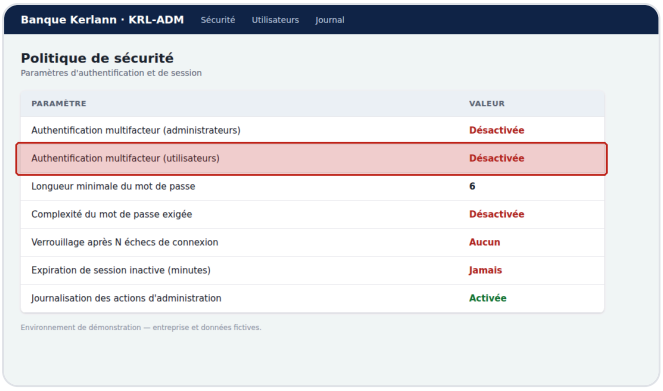
RISK

Without MFA for all users, compromised user credentials allow unauthorized access to critical functions

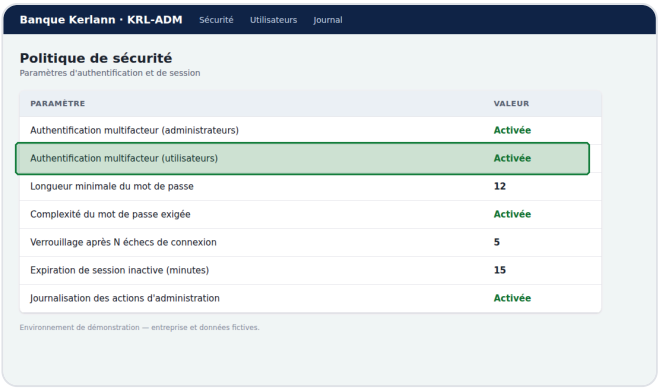
RECOMMENDATION

Enable mandatory MFA for standard users by setting mfa_users to true
Due date: 2027-02-02 · Owner: IT department — IAM team

Test procedure: Retrieve the security configuration via GET /api/security and verify that mfa_users is true



At testing — The screenshot corroborates the test. The screenshot shows user MFA as Desactivee, matching the automated test failure.
`2026-11-04 00:15:08 · SHA-256 c8e5e978d1fe2eb3…`



After fix — The screenshot corroborates the test. The screenshot shows user MFA as Activée, matching the automated pass result.
`2026-11-04 00:15:52 · SHA-256 216749727129812a…`

> **Change request CHG-AUD-2026-IAM-01-02** · `PATCH /api/security {"mfa_users": true}`
> MFA must be enforced for standard users because KRL-ADM supports critical functions.
> Expected impact: Standard users will be required to use MFA at next login.
> Approved by: **IAM owner (CI)** · 2026-11-04 00:15:39 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-04T00:15:39Z · svc-change · mfa_users: False → True

F-03 PSI-4.7 No generic or shared admin accounts

High · Non-compliant · Action plan

CRITERIA

No account with role admin is generic or shared and every admin has a nominative login of the form initiale.nom with a personal email

PSI-4.7 · DORA 9(4)(c), RTS 21(1)(c), RTS 21(1)(e)(ii)

CONDITION

Observed: `[{"login": "a.lefloch", "email": "a•••@kerlann-banque.example", "role": "admin"}, {"login": "ops", "email": "o•••@kerlann-banque.example", "role": "admin"}]`

Expected: `for all users where role == admin: login matches initiale.nom pattern and email is personal, with no function login and no shared mailbox`

1 of 2 admin account(s) violate nominative login or personal email requirements.

RISK

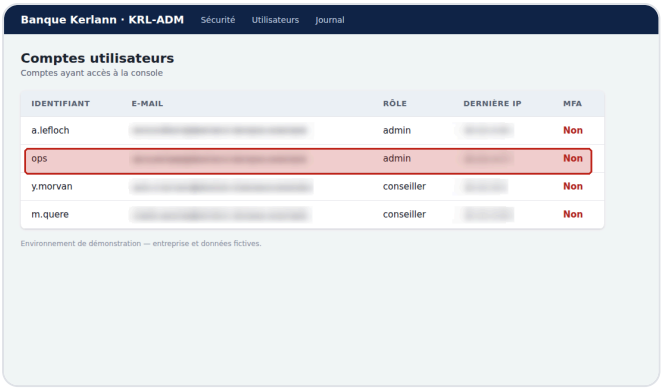
Generic or shared admin accounts destroy individual accountability and prevent attribution of privileged actions

RECOMMENDATION

Remove or disable generic and shared admin accounts and replace them with dedicated nominative accounts

Due date: 2027-02-02 · Owner: IT department — IAM team

Test procedure: Retrieve all accounts via GET /api/users and verify that every user with role admin has a nominative login and a personal email without function identifier or shared mailbox



At testing — The screenshot corroborates the test. The screenshot shows two admin accounts including generic login ops with shared mailbox, confirming the reported violation. · 8/8 sensitive data items masked

`2026-11-04 00:15:26 · SHA-256 48d7967ae6c8b838…`

> **Manual remediation** · CHG-AUD-2026-IAM-01-03
> Generic shared admin account destroys individual accountability and prevents attribution of privileged actions.
>
> 1. Disable and remove the shared admin account login 'ops' with email 'ops-partage@kerlann-banque.example'
> 2. Provision dedicated nominative admin accounts in initiale.nom form with personal email for each individual requiring privileged access
> 3. Review /admin/journal for actions performed by the shared account and re-verify via GET /api/users that all remaining admin accounts are nominative with personal email

F-04 PSI-4.3 Strong password policy

Medium · Non-compliant → Compliant

Re-tested compliant — closure pending owner approval

CRITERIA

Passwords require a minimum length of 12 characters with complexity requirements enabled

PSI-4.3 · DORA 9(4)(d)

CONDITION

Observed: `{"password_min_length": 6, "password_require_complexity": false}`

Expected: `password_min_length >= 12 AND password_require_complexity == true`

password_min_length is 6 and password_require_complexity is False.

RISK

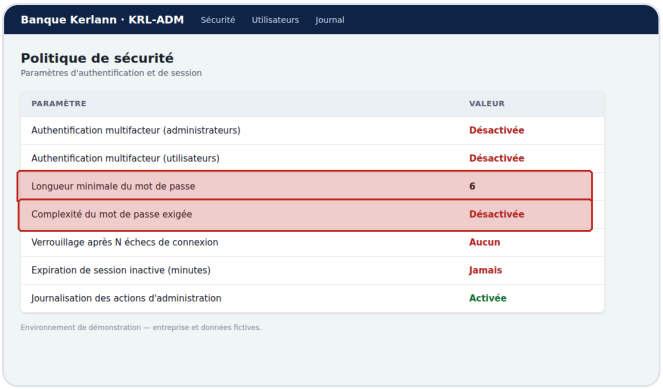
Weak or short passwords can be guessed or brute-forced, enabling unauthorized access to the system

RECOMMENDATION

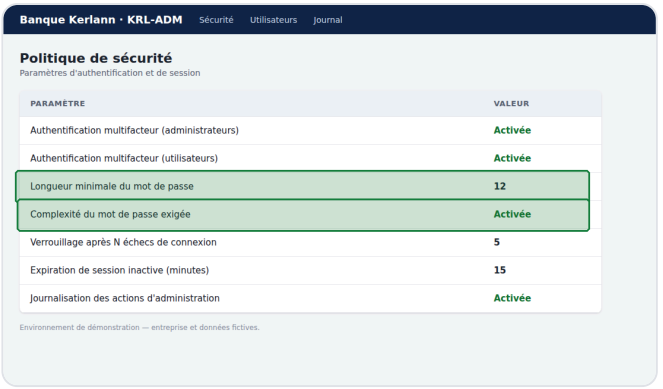
Enforce a minimum password length of 12 characters with complexity by correcting the password settings

Due date: 2027-05-03 · Owner: IT department — IAM team

Test procedure: Retrieve the security configuration via GET /api/security and verify password_min_length and password_require_complexity



At testing — The screenshot corroborates the test. Screenshot shows minimum length 6 and complexity disabled, matching the failed automated check.
`2026-11-04 00:15:08 · SHA-256 1c48df04737588f1…`



After fix — The screenshot corroborates the test. Screenshot shows minimum length 12 and complexity Activée, matching the automated pass result.
`2026-11-04 00:15:53 · SHA-256 fa843810fb3c4f95…`

> **Change request CHG-AUD-2026-IAM-01-04** · `PATCH /api/security`
> `{"password_min_length": 12, "password_require_complexity": true}`
> Sets minimum password length to 12 and enables complexity to satisfy PSI-4.3.
> Expected impact: Users with shorter or simple passwords will be required to create stronger passwords meeting the new policy.
> Approved by: **IAM owner (CI)** · 2026-11-04 00:15:39 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-04T00:15:39Z · svc-change · password_min_length: 6 → 12; password_require_complexity: False → True

F-05 PSI-4.4 Account lockout after failed logins

Medium · Non-compliant → Compliant

Re-tested compliant — closure pending owner approval

CRITERIA

Accounts lock after at most 5 failed login attempts and lockout is never disabled
PSI-4.4 · DORA 9(4)(c)

CONDITION

Observed: `0`
Expected: `lockout_threshold >= 1 AND lockout_threshold <= 5`
lockout_threshold is 0, which is outside the required range 1 to 5 inclusive.

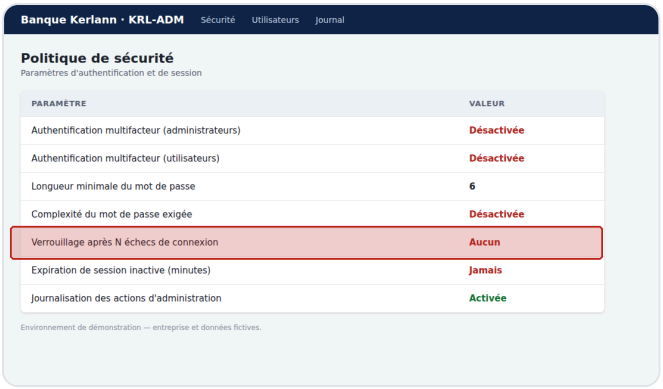
RISK

Without lockout, attackers can perform unlimited password-guessing attacks against accounts

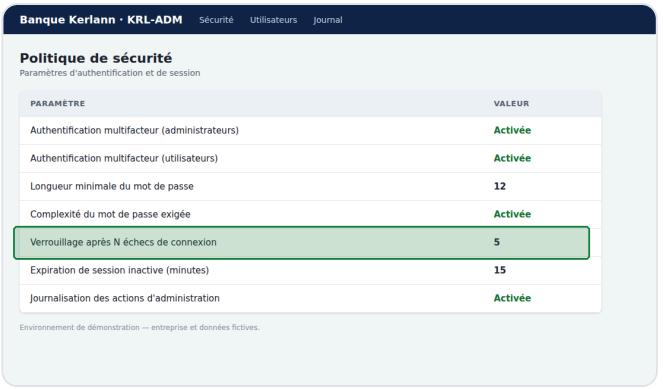
RECOMMENDATION

Configure account lockout to 5 attempts at most by setting lockout_threshold between 1 and 5
Due date: 2027-05-03 · Owner: IT department — IAM team

Test procedure: Retrieve the security configuration via GET /api/security and verify that lockout_threshold is between 1 and 5 inclusive



At testing — The screenshot corroborates the test. The security policy shows lockout set to Aucun, confirming disabled lockout.
`2026-11-04 00:15:04 · SHA-256 2b3d2dfd33163d9e…`



After fix — The screenshot corroborates the test. The screenshot shows lockout after 5 failed attempts, matching the automated test result.
`2026-11-04 00:15:53 · SHA-256 f02b0179301979e7…`

> **Change request CHG-AUD-2026-IAM-01-05** · `PATCH /api/security {"lockout_threshold": 5}`
> Lockout is currently disabled (0), so setting the threshold to 5 restores compliance with PSI-4.4.
> Expected impact: Accounts will lock after 5 failed login attempts and will require unlock or reset.
> Approved by: **IAM owner (CI)** · 2026-11-04 00:15:40 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-04T00:15:40Z · svc-change · lockout_threshold: 0 → 5

F-06 PSI-4.5 Inactive session timeout

Medium · Non-compliant → Compliant

Re-tested compliant — closure pending owner approval

CRITERIA

Inactive sessions expire after at most 15 minutes and expiration is never disabled
PSI-4.5 · DORA 9(4)(c)

CONDITION

Observed: `0`
Expected: `session_timeout_minutes >= 1 AND session_timeout_minutes <= 15`
Observed session_timeout_minutes is 0, outside the required 1 to 15 inclusive.

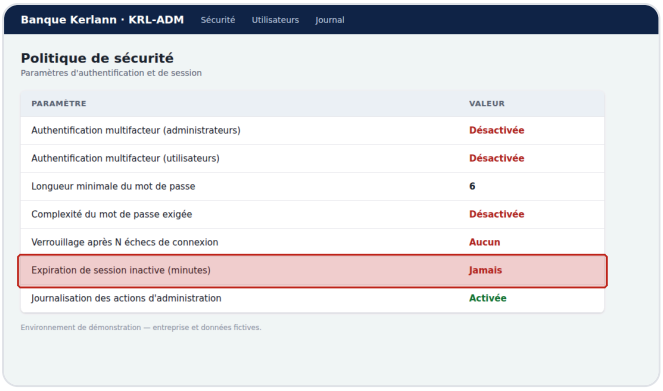
RISK

Unlimited inactive sessions allow session hijacking and unauthorized use of unattended workstations

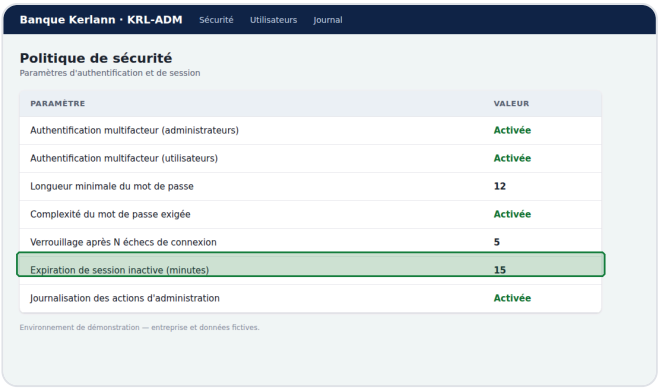
RECOMMENDATION

Enforce inactive session expiration at 15 minutes at most by setting session_timeout_minutes between 1 and 15
Due date: 2027-05-03 · Owner: IT department — IAM team

Test procedure: Retrieve the security configuration via GET /api/security and verify that session_timeout_minutes is between 1 and 15 inclusive



At testing — The screenshot corroborates the test. The table shows inactive session expiration set to Jamais, confirming the automated failure.
`2026-11-04 00:15:20 · SHA-256 19dd29ed4d170b6e…`



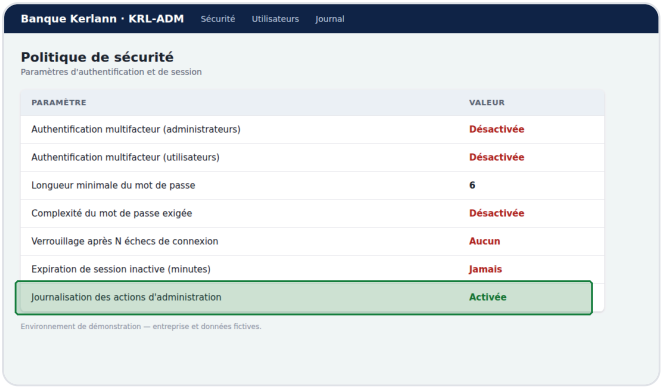
After fix — The screenshot corroborates the test. Screenshot shows inactive session expiration set to 15 minutes.
`2026-11-04 00:16:04 · SHA-256 4a97df65be09dcbe…`

> **Change request CHG-AUD-2026-IAM-01-06** · `PATCH /api/security`
> `{"session_timeout_minutes": 15}`
> Set session_timeout_minutes to 15 to bring the observed value 0 into the required 1 to 15 range. Expected impact: Inactive users will be logged out after 15 minutes of inactivity and need to sign in again.
> Approved by: **IAM owner (CI)** · 2026-11-04 00:15:40 · pre-approved (demo, not valid as an approval) · applied and logged
> System journal: 2026-11-04T00:15:40Z · svc-change · session_timeout_minutes: 0 → 15

PSI-4.6 Logging of administration actions

High · Compliant

Compliant control — All administration actions are logged · RTS 12(2)(c)(i)
Observed: `true`



At testing — The screenshot corroborates the test. The screenshot shows admin action logging as Activée, matching the passing automated test.
`2026-11-04 00:15:19 · SHA-256 07036fd4bb987f6b…`

Appendices

A. Traceability matrix

REQUIREMENT	RULE	CONTROL	SCRIPT (SHA-256)	RESULT
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.1	C1 · Mandatory MFA for privileged accounts	098d37cd0158dd1a · script library (reused)	Non-compliant → Compliant
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.2	C2 · Mandatory MFA for users of critical system	fa35c17fbb1dfdd3 · script library (reused)	Non-compliant → Compliant
DORA 9(4)(d)	PSI-4.3	C3 · Strong password policy	b440a5b4dc6b0fb3 · script library (reused)	Non-compliant → Compliant
DORA 9(4)(c)	PSI-4.4	C4 · Account lockout after failed logins	10d2a8f06337b5bc · script library (reused)	Non-compliant → Compliant
DORA 9(4)(c)	PSI-4.5	C5 · Inactive session timeout	4157e9750f010f98 · script library (reused)	Non-compliant → Compliant
RTS 12(2)(c)(i)	PSI-4.6	C6 · Logging of administration actions	e2f3534909210977 · script library (reused)	Compliant
DORA 9(4)(c), RTS 21(1)(c), RTS 21(1)(e)(ii)	PSI-4.7	C7 · No generic or shared admin accounts	5e917770866b8e47 · script library (reused)	Non-compliant

B. Evidence register

FILE			SHA-256
evidence/C1_before.png	C1 · At testing	2026-11-04 00:15:08	7e61f61ba345e75d6737408c0cff1ccadddfb8c4a3a4323c4d51124a5b198b80
evidence/C1_after.png	C1 · After fix	2026-11-04 00:15:53	df9e11e666120d20b544f2ffc3995a7a7228833e9e1e91817624aadaaa0f22c6
evidence/C2_before.png	C2 · At testing	2026-11-04 00:15:08	c8e5e978d1fe2eb3c62d015970479d83830bcfe925f71ed47f7624dc48e8133e
evidence/C2_after.png	C2 · After fix	2026-11-04 00:15:52	216749727129812ab18d396430c575644106c99e9e7aa065a1625564c4867931
evidence/C3_before.png	C3 · At testing	2026-11-04 00:15:08	1c48df04737588f1fdd7b8de74b7a6d330585b7306eb38bc0a54c7585ac9ba0d
evidence/C3_after.png	C3 · After fix	2026-11-04 00:15:53	fa843810fb3c4f950cc510796babb38671ad5c581fe4610f053807f46b88de00
evidence/C4_before.png	C4 · At testing	2026-11-04 00:15:04	2b3d2dfd33163d9e34b207442f45fd634c0931007c4f569db10f489e316c6486
evidence/C4_after.png	C4 · After fix	2026-11-04 00:15:53	f02b0179301979e75f441851b9d17ae57e645a1766a57b736dff49aba43e22fc

evidence/C5_before.png	C5 · At testing	2026-11-04 00:15:20	19dd29ed4d170b6e4deca9af59e5ea3f5c98f1c669b69b9c7bfbed9facc676e2
evidence/C5_after.png	C5 · After fix	2026-11-04 00:16:04	4a97df65be09dcbe33d2673b234c05c9397ae4e25b52b9d338fada79cbe7acca
evidence/C6_before.png	C6 · At testing	2026-11-04 00:15:19	07036fd4bb987f6bdd5e3d59d80d6d762164b60af73816d4cb60265a331c87a3
evidence/C7_before.png	C7 · At testing	2026-11-04 00:15:26	48d7967ae6c8b83829ac915e2a2d80dd40eff7f2ad2876dc8bf08aefb7d65cd7
evidence/journal.png	System journal		4ce5e464ee5e0f7bcd4a1f5fbb4332f21fcfbb32c7f22866dfdda78824e6fbbd

C. AI usage, costs and human oversight

MODEL	CALLS	INPUT TOKENS	OUTPUT TOKENS	IMAGES	COST (USD)
muse-spark-1.3	18	22,593	22,875	0	0.1255
sam-3.1	12	0	0	12	price not published
Total					**0.1255**

Sensitive data (personal data and secrets) in evidence: 8/8 spotted by Muse Spark + SAM, 8/8 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

Human decisions

TICKET	REF.		APPROVED BY	MODE	DATE
CHG-AUD-2026-IAM-01-01	F-01	✔	IAM owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-04 00:15:39
CHG-AUD-2026-IAM-01-02	F-02	✔	IAM owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-04 00:15:39
CHG-AUD-2026-IAM-01-04	F-04	✔	IAM owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-04 00:15:39
CHG-AUD-2026-IAM-01-05	F-05	✔	IAM owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-04 00:15:40
CHG-AUD-2026-IAM-01-06	F-06	✔	IAM owner (CI)	pre-approved (demo, not valid as an approval)	2026-11-04 00:15:40

Safeguards

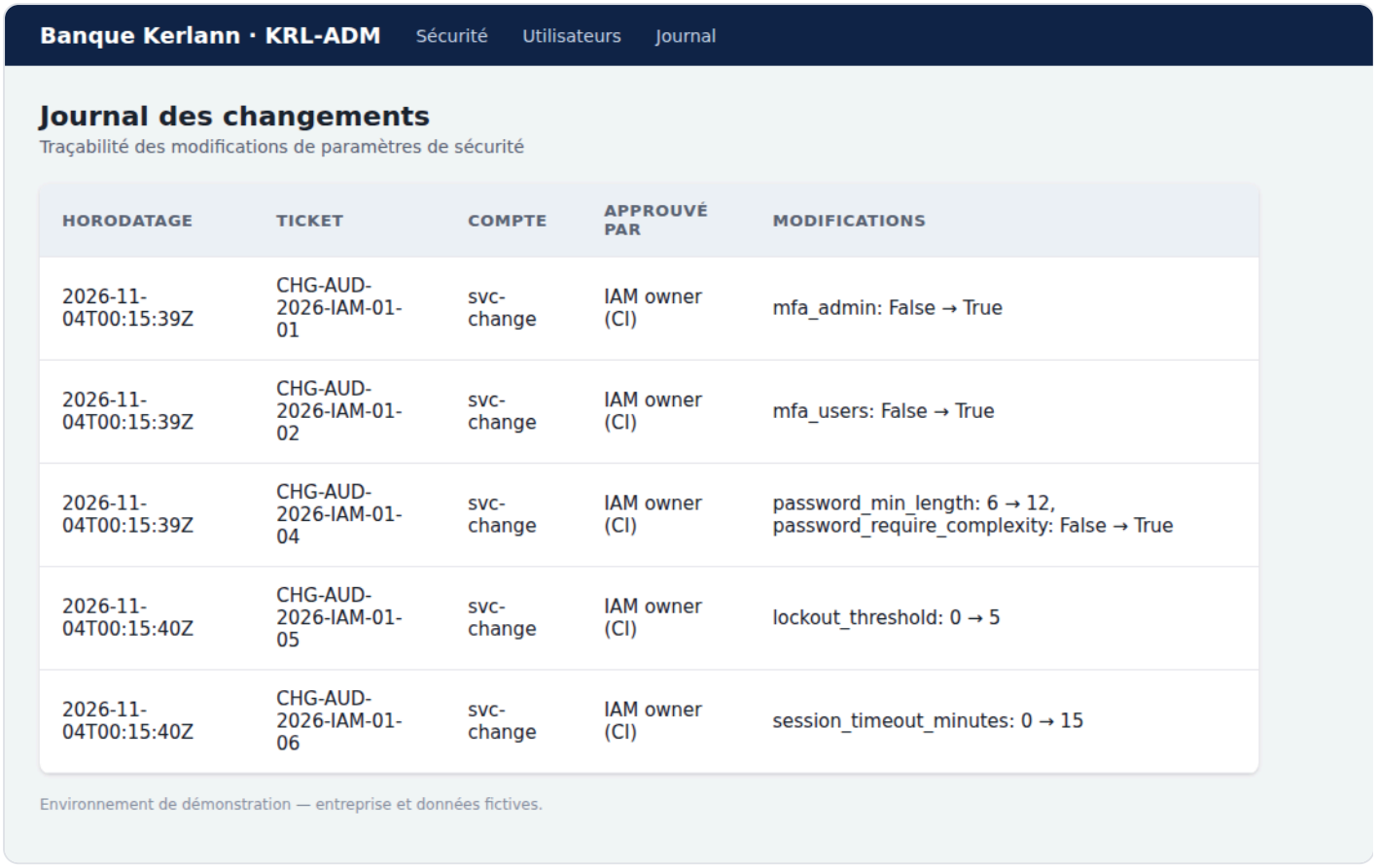
- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

`25dac3d3b083d37b7f73f15de721ec63b65e188a3c04afef5ea840573c843f7e`

E. Change log of the audited system



Banque Kerlann · KRL-ADM Sécurité Utilisateurs Journal

Journal des changements

Traçabilité des modifications de paramètres de sécurité

HORODATAGE	TICKET	COMPTE	APPROUVÉ PAR	MODIFICATIONS
2026-11-04T00:15:39Z	CHG-AUD-2026-IAM-01-01	svc-change	IAM owner (CI)	mfa_admin: False → True
2026-11-04T00:15:39Z	CHG-AUD-2026-IAM-01-02	svc-change	IAM owner (CI)	mfa_users: False → True
2026-11-04T00:15:39Z	CHG-AUD-2026-IAM-01-04	svc-change	IAM owner (CI)	password_min_length: 6 → 12, password_require_complexity: False → True
2026-11-04T00:15:40Z	CHG-AUD-2026-IAM-01-05	svc-change	IAM owner (CI)	lockout_threshold: 0 → 5
2026-11-04T00:15:40Z	CHG-AUD-2026-IAM-01-06	svc-change	IAM owner (CI)	session_timeout_minutes: 0 → 15

Environnement de démonstration — entreprise et données fictives.

`SHA-256 4ce5e464ee5e0f7bcd4a1f5fbb4332f21fcfbb32c7f22866dfdda78824e6fbbd`